



PRESCIENT
SECURITY

Normain™

Management System Audit Report

Normain AB

ISO/IEC 27001:2022

Initial Certification Audit – 2025

Report Version # 1.0

TABLE OF CONTENTS

SECTION 1

General Information

- Executive Summary
 - *Introduction*
 - *Organization & Audit Information*
 - *Audit Objectives*
 - *Audit Scope*
 - *Audit Criteria*
 - *Audit Team*
 - *Audit Methodology*
 - *Findings & Nonconformities*
 - *Summary of Information Security Risk Analysis*

SECTION 2

Audit Information

- Scope of Certification
- Audit Planning

SECTION 3

Audit Summary

- Audit Attendees
- Audit Test Details
 - *Clauses*
 - *Annex A*
- Audit Findings – Initial Certification
- Audit Finding Definitions
- Stage 2 Certification Audit – Findings and Outcomes

SECTION 4

Audit Conclusions & Audit Team Recommendations

- Audit Conclusions and Audit Recommendations

SECTION 1:

GENERAL INFORMATION

EXECUTIVE SUMMARY

Introduction

This executive summary provides an overview of the audit and outcomes of the ISO/IEC 27001:2022 initial certification audit conducted by Prescient Security.

Organization & Audit Information

Normain AB provides a platform designed to support its clients in automation in documents for compliance, auditing, due diligence, and sustainability.

Normain AB was incorporated in 2024 and located in Stockholm, Sweden.

Company Name	Normain AB
Company Address	c/o SSE Business Lab, Stockholm School of Economics, Box 6501, Stockholm, Sweden
Website	https://normain.com/
Phone Number	46768642642
Client Representative Name	Sara Landfors
Client Representative Email	sara@normain.com
Total Number of Employees within the Scope	6
Audit Standard(s)	ISO/IEC 27001:2022
Audit Number	ISO - 16876
Audit Type	Initial Certification
Duration	5 Days
Audit Dates	Stage 1: July 15 - 16, 2025 Stage 2: July 24 - 28, 2025
Lead Auditor	Barry Jones
Additional Team Member(s)	N/A
Additional Attendees and Roles	Sara Landfors - CEO & Co-founder Dennis Landfors - COO & Co-founder Gustav Liden - Founding Engineer
Method of Audit	Audit was performed remotely via Microsoft Teams.
Joint, Combined, Integrated Audit?	N/A

Audit Objectives

The primary objectives of the audit were to:

- Assess the compliance of the organization’s Information Security Management System (ISMS) with ISO/IEC 27001:2022.
- Determine the effectiveness of the implemented management systems.
- Identify any areas of non-conformities

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

- Ensure, based on the risk assessment, has identified the necessary controls
- Determine that the established information security objectives have been achieved

Audit Scope

The audit covered the following areas:

- Organizational and functional units
- Processes and activities relevant to the scope of certification
- Review of documentation and records
- Interviews with key personnel

Audit Criteria

The audit criteria were based on the requirements of ISO/IEC 27001:2022.

Audit Team

The audit was conducted by a team of qualified auditors from Prescient Security, with expertise in information security management.

Audit Methodology

The audit methodology included:

- Review of documented information (policies, procedures, records)
- On-site and remote interviews with key personnel
- Observation of processes and activities
- Sampling of records and evidence
- Evaluation of corrective actions from previous non-conformities, if applicable

Findings & Nonconformities

Major Nonconformities	Minor Nonconformities	Observations	Opportunity for Improvement
0	0	4	1

Summary of Information Security Risk Analysis

Normain AB employs a structured approach to assessing and managing information security risks, aligning with guidelines from NIST 800-30. The process begins with preparation for risk assessment, where the company establishes the assessment's context by identifying its purpose, scope, assumptions, and constraints. This involves determining the information to be produced, the decisions it will support, and gathering necessary data such as architectural diagrams, legal requirements, and identifying potential threats, vulnerabilities, and existing controls.

The second phase of the process is conducting the risk assessment itself, which includes identifying threat sources and events, assessing vulnerabilities, determining the likelihood of threat occurrence, and evaluating the potential impact on Normain AB's business operations and objectives. This stage is crucial for producing a prioritized list of security risks based on their likelihood and potential impact, which will inform risk response decisions.

The final phases involve communicating the assessment results to decision-makers and maintaining the risk assessment over time. Communication ensures that all pertinent personnel are informed and can participate in risk management decisions. The ongoing maintenance includes monitoring risk factors and updating the assessment annually or as needed to adapt to changes in the risk landscape, ensuring that Normain AB remains proactive in managing threats to its information security.

The above information is in accordance with their Risk Management Policy which provides assurance that the risk register is implemented appropriately and is operating effectively.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

Conclusion

The audit concluded that the organization's ISMS is generally compliant with the requirements of ISO/IEC 27001:2022. Referring to the results of the audit process and the demonstration of the organization's development and maturity, the audit team recommends that your organization's management system should be granted certification for ISO/IEC 27001:2022.

Barry Jones

Barry Jones

SECTION 2:

AUDIT INFORMATION

SCOPE OF CERTIFICATION

Scope of Certification	The scope of the ISO/IEC 27001:2022 certification is limited to the Information Security Management System (ISMS) for Normain AB. The Company provides a web-based software service enabling customers to build, test, and deploy AI-augmented automations of their business processes. The scope of the ISMS includes the assets, technologies, and processes utilized by the company to deliver its services. The scope includes infrastructure hosted on Azure. The ISMS scope also includes the following departments: Engineering, Human Resources, Information Technology, Information Security, Legal, Finance. This is in accordance with the Statement of Applicability.
Version & Date of SoA	Version 1.0.1 dated July 17, 2025

The Initial Certification audit (Stage 1 and Stage 2) was performed remotely in accordance with IAF MD 4:2023. The organization is remote and fully cloud hosted. There were no physical locations within the scope of the ISMS for this audit.

Location / Affiliate / Subsidiary	Address	Function / Role in ISMS
N/A	N/A	N/A

AUDIT PLANNING

Audit Objectives

Prescient Security has planned the audit in accordance with ISO/IEC 17021-1, ISO/IEC 27006-1, and Prescient Security’s own policies and procedures to ensure that the following audit objectives are accomplished by the audit:

- Determining the ISMS’s conformity, or parts of it, with the audit criteria (ISO/IEC 27001:2022);
- Determining the ability of the management system to ensure the organization meets applicable, statutory, regulatory and contractual requirements;
- Determining the effectiveness of management system to ensure the organization can reasonably expect to achieve its specified objectives;
- When applicable, identifying areas for potential improvement of the ISMS.

Prescient Security performed an Initial Certification in two stages, Stage 1 and Stage 2. This report details the audit, findings, and outcomes of the Stage 2 audit.

The purpose of the Stage 2 audit is to evaluate the implementation, including effectiveness, of Normain AB’s ISMS. In addition to the evaluating the effective implementation of the ISMS, the objective of the Stage 2 is to confirm adherence to policies, procedures, objectives and procedures. The Stage 2 Audit also focused on the following:

- Information and evidence about conformity ISO/IEC 27001 and/or other normative standards;
- Performance monitoring, measuring, reporting and reviewing against key performance objectives and targets (consistent with the expectations of ISO/IEC 27001 and/or other normative documents);
- The ISMS’s ability and its performance regarding meeting of applicable statutory, regulatory and contractual requirements;
- Operational control of the client’s processes;
- Internal auditing and management review;
- Management responsibility for the client’s policies.

The audit team focused on the top management’s leadership and commitment to the information security objectives, assessment of information security related risks ensuring that the assessments procedures consistent, valid and comparable results, if repeated, determination of controls based on the information security risk assessment and treatment processes, correspondence between the determined controls of the SoA, the results of the information security risk assessment and

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

treatment process, and the information security policy and objectives. The auditor paid special attention to the implementation of controls considering the external and internal context and related risks, and the monitoring, measurement and analysis of information security processes and controls, to determine whether controls declared as being implemented are actually implemented and effective as a whole. Lastly, the audit was focused on programs, processes, procedures, records, internal audits and reviews of the ISMS effectiveness to ensure that these are traceable to top management decisions and the information security policy and objectives.

Audit Scope

The audit scope covered the documentation requirements of the ISO/IEC 27001 standard, as well as the associated testing, which included evidence of the monitoring, maintenance, and operating effectiveness of the ISMS and test of the applicable control framework, relevant to the audit scope. The audit program included the following, all relevant to the scope of the audit scope:

Audit Scope	Additional Details / Information
The organizational units	Normain AB
IT Infrastructure	Managed by third party Cloud Service Provider (CSP) – Microsoft Azure
Software/Service	Normain AB provides a web-based software service enabling customers to build, test, and deploy AI-augmented automations of their business processes.
Departments	Engineering Human Resources Information Technology Information Security Legal Finance
Processes	All processes relevant to the ISMS

Audit Criteria

The audit criteria are used as a reference against which conformity is determined. The audit criteria for this audit were ISO/IEC 27001:2022, Clauses 4-10 and Annex A security controls as per the established SoA, and the documentation of the management system (policies, procedures, records, objectives) developed by Normain AB.

Audit Methodology

The audit team conducted a process-based audit focusing on significant aspects, risks and objectives. The auditors have used audit procedures to collect evidence in order to validate the conformity of the ISMS. The use of audit procedures in a systematic way reduces the audit risk and reinforces the objectivity of the audit conclusions.

Normain AB does not have any activities within the scope of the certification that are undertaken at a defined physical location. All activities are conducted remotely, with employees working from home (WFH). The Initial Certification Audit was performed 100% remotely due to the nature of the client’s business.

In accordance with ISO/IEC 17021-1 and ISO/IEC 27006, the audit was conducted to ensure that all requirements and aspects of the ISMS were met despite the remote nature of the business operations. The audit methodology adhered to the guidelines set forth in IAF MD 4 for the use of Information and Communication Technology (ICT) for auditing and assessment purposes. Microsoft Teams was utilized as the primary tool for conducting remote audit activities, enabling effective communication, document sharing, and real-time verification of compliance. Vanta, was utilized to streamline and manage its compliance processes. The automation capabilities of the compliance platform were used to provide continuous monitoring and real-time evidence collection, significantly enhancing the efficiency and effectiveness of the audit. Prescient Security facilitated the offsite documentation review of electronic evidence submissions via Vanta compliance automation platform.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

Risks Associated with Remote Audits and Mitigation Measures:

Communication Challenges: The potential for miscommunication was mitigated by using high-quality video conferencing tools, scheduled frequent check-ins, and clear, concise documentation.

Data Security Concerns: Ensured secure transmission of sensitive documents through encrypted channels and secure cloud storage solutions.

Limited Observability: Compensated by increased sampling and additional interviews with multiple personnel to cross-verify information.

Reliance on Automation: Ensured that the data and evidence collected by Vanta were accurately represented and validated through cross-checks and manual review where necessary.

Despite the remote execution of the audit, all audit objectives were fully achieved. The objective of remote auditing techniques should be to enhance audit effectiveness and efficiency, and to support the integrity of the audit process.

The audit confirmed that Normain AB has implemented a robust ISMS that meets the stringent requirements of ISO/IEC 27001:2022. All audit objectives were accomplished, and the audit findings provide sufficient evidence that there is effective control over its information security risks, even in a remote working environment.

The analysis procedure allows the audit team to draw conclusions concerning a whole by examining a part. It allows the auditor to estimate characteristics of a population by directly observing a part of the whole population. Technical tests, including testing of the effectiveness of a process or control have not been performed by the auditor themselves. The operations have always been performed by the personnel of the auditee.

Audit Planning

Prescient Security has established an initial contact with the auditee to make arrangements for this audit, including scheduling the dates. The Lead Auditor has validated the feasibility of the audit, the audit objectives, the audit scope, the location, and the audit criteria.

The audit plan was sent to the auditee, and it was discussed during the opening meeting between the audit team and the auditee.

The remote audit was started with an opening meeting which has been attended by the individuals responsible for the ISMS. The Prescient Security overview, audit purpose, methodology, reporting system, appeal process and confidentiality were briefly presented to the client during the opening meeting.

The interval between the Stage 1 and Stage 2 audits were determined based on the client's readiness to address the areas of concern identified during the Stage 1 audit. The audit team informed Normain AB that these concerns needed to be addressed before proceeding to Stage 2.

The audit team considered the plan and timeframe for addressing the concerns and scheduled the Stage 2 audit accordingly. No significant changes impacting the management system were identified that would require repeating any part of Stage 1.

The auditor reviewed the updates and changes made during the Stage 2 audit to ensure all areas of concern from Stage 1 were addressed.

There were no deviations or significant issues from the audit plan.

SECTION 3:

AUDIT SUMMARY

AUDIT ATTENDEES

Opening Meeting

Name	Position / Title
Client Representative	
Sara Landfors	CEO & Co-Founder
Dennis Landfors	COO & Co-Founder
Gustav Liden	Founding Engineer
Audit Team	
Barry Jones	Lead Auditor

Closing Meeting

Name	Position / Title
Client Representative	
Sara Landfors	CEO & Co-Founder
Dennis Landfors	COO & Co-Founder
Gustav Liden	Founding Engineer
Audit Team	
Barry Jones	Lead Auditor

AUDIT TEST DETAILS

Notes on usage by the auditor:

Under the column “Status of Finding”, please use the following key to record your assessment result for each clause:

Key	Description
C	Conformity
N/A	Not Applicable (Out of Scope)
MaNC	Major Nonconformity
MiNC	Minor Nonconformity
OBS	Observation
OFI	Opportunity for Improvement

Clauses

Clause Requirement		Status of Finding	Audit Evidence (Finding and its Justification)
4. Context of the Organization			
4.1	Understanding the Organization and Its context	C	01-isms-scope-of-the-isms version 1.0.0 dated 6/6/25. Context defined with internal & external issues detailed within Appendix C of document. Fully meets the respective clause/control requirement.
4.2	Understanding the Needs and Expectations of Interested Parties	C	01-isms-scope-of-the-isms version 1.0.0 dated 6/6/25. Appendix B details the needs and expectations of interested parties. Fully meets the respective clause/control requirement.
4.3	Determining the scope of the ISMS	C	01-isms-scope-of-the-isms version 1.0.0 dated 6/6/25. The company has determined its scope of the management system, which includes interfaces and dependencies within scope exclusions and boundaries. Updated document for stage 2 audit includes details relevant to office locations no longer within scope. Fully meets the respective clause/control requirement.
4.4	Information security management system	C	01-isms-scope-of-the-isms version 1.0.0 dated 6/6/25. 02-isms-information-security-management-system-isms-policy version 1.0.0 dated 30/5/25. Framework for the management system determined and available within Vanta platform. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

5. Leadership			
5.1	Leadership and commitment	C	02-isms-information-security-management-system-isms-policy version 1.0.0 dated 30/5/25. information-security-policy-bsi version 1.0.0 dated 30/5/25. 03-isms-roles-responsibilities-and-authorities Leadership and top management responsibilities with the management system have been determined. Fully meets the respective clause/control requirement.
5.2	Policy	C	02-isms-information-security-management-system-isms-policy version 1.0.0 dated 30/5/25. information-security-policy-bsi version 1.0.0 dated 30/5/25. Commitment requirements are determined within the ISMS Policy. 10-isms-information-security-objectives-plan. Fully meets the respective clause/control requirement.
5.3	Organizational roles, responsibilities and authorities	C	03-isms-roles-responsibilities-and-authorities Senior Management are accountable for the review and adequate delegation of ISMS roles and responsibilities. Fully meets the respective clause/control requirement.
6. Planning			
6.1	<i>Actions to address risks and opportunities</i>		
6.1.1	General	C	04-isms-risk-assessment-and-risk-treatment-process version 1.0.0 dated 30/5/25. 09-isms-procedure-for-corrective-action-and-continual-improvement version 1.0.0 dated 30/5/25. Risk Assessment Snapshot 2025-06-06 Methodology around completing and reviewing risk assessments is in place and detailed. Fully meets the respective clause/control requirement.
6.1.2	Information security risk assessment	C	04-isms-risk-assessment-and-risk-treatment-process version 1.0.0 dated 30/5/25. risk-management-policy-bsi Risk Assessment Snapshot 2025-06-06 Clarification on the methods taken risk assessment and acceptance criteria detailed, including actions taken in the management of residual risk. Updated risk snapshot observed for stage 2 audit Risk Assessment Snapshot 2025-07-23. Fully meets the respective clause/control requirement.
6.1.3	Information security risk treatment	C	04-isms-risk-assessment-and-risk-treatment-process version 1.0.0 dated 30/5/25. risk-management-policy-bsi Risk Assessment Snapshot 2025-06-06 Actions on risk treatment detailed. Statement of applicability is in place 11-isms-statement-of-applicability version 1.0.1 dated 17/07/2025. Outsourced development is justified as an exclusion. Physical controls updated as excluded. Fully meets the respective clause/control requirement.
6.2	Information security objectives and planning to achieve them	C	10-isms-information-security-objectives-plan Detailed performance objectives against the management system and controls in place.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

			Fully meets the respective clause/control requirement.
6.3	Planning of Changes	C	information-security-policy-bsi operations-security-policy-bsi risk-management-policy-bsi Actions to address changes within the management system are detailed in relevant policy documents and further discussed during management review. isms_management_review_2025-06-09. Fully meets the respective clause/control requirement.
7. Support			
7.1	Resources	C	02-isms-information-security-management-system-isms-policy version 1.0.0 dated 30/5/25. 03-isms-roles-responsibilities-and-authorities Resources necessary for the fulfilment of the management system are detailed. Fully meets the respective clause/control requirement.
7.2	Competence	C	Details on the approach to finding appropriate talent for the organisation is detailed within the Normain Talent Lifecycle Handbook as available within competence_is_evaluated_prior_to_offer_and_hiring-links human-resource-security-policy-bsi Competence detailed within relevant CVs for Directors and LinkedIn profiles: https://www.linkedin.com/in/guslid/ https://www.linkedin.com/in/kalle-hansson/ https://www.linkedin.com/in/landfors/. Fully meets the respective clause/control requirement.
7.3	Awareness	C	information-security-policy-bsi 06-isms-information-security-communication-plan People-2025-07-15-110933 All live personnel have completed relevant general security awareness training. Fully meets the respective clause/control requirement.
7.4	Communication	C	06-isms-information-security-communication-plan Detailed communication plan in place. Fully meets the respective clause/control requirement.
7.5	Documented Information		
7.5.1	General	C	05-isms-procedure-for-the-control-of-documented-information 00-isms-master-list-of-documents. Fully meets the respective clause/control requirement.
7.5.2	Creating and Updating	C	05-isms-procedure-for-the-control-of-documented-information 00-isms-master-list-of-documents. Fully meets the respective clause/control requirement.
7.5.3	Control of documented information	C	05-isms-procedure-for-the-control-of-documented-information version 1.0.0 dated 30/5/25. 02-isms-information-security-management-system-isms-policy version 1.0.0 dated 30/5/25. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

8. Operation			
8.1	Operational planning and control	C	02-isms-information-security-management-system-isms-policy risk-management-policy-bsi 10-isms-information-security-objectives-plan Processes completed by the company detailed by relevant departments, operational security controls included within the management system are detailed within the SoA. 11-isms-statement-of-applicability. Fully meets the respective clause/control requirement.
8.2	Information security risk assessment	C	04-isms-risk-assessment-and-risk-treatment-process version 1.0.0 dated 30/5/25. risk-management-policy-bsi Risk Assessment Snapshot 2025-06-06 Clarification on the methods taken risk assessment and acceptance criteria detailed, including actions taken in the management of residual risk. Fully meets the respective clause/control requirement.
8.3	Information security risk treatment	C	04-isms-risk-assessment-and-risk-treatment-process version 1.0.0 dated 30/5/25. risk-management-policy-bsi Risk Assessment Snapshot 2025-06-06 Clarification on the methods taken risk assessment and acceptance criteria detailed, including actions taken in the management of residual risk. Fully meets the respective clause/control requirement.
9. Performance Evaluation			
9.1	Monitoring, measurement, analysis and evaluation	C	10-isms-information-security-objectives-plan Review of business performance conducted against objectives. Personnel performance reviewed and detailed within review_2025-06-03. Fully meets the respective clause/control requirement.
9.2	Internal Audit		
9.2.1	General	C	07-isms-procedure-for-internal-audits version 1.0.0 dated 30/05/25 Internal audit completed and reported within: normain_2025_06_12_18_14_02_v1 A review against all clauses and controls has been completed with outputs identified. Fully meets the respective clause/control requirement.
9.2.2	Internal Audit Programme	C	07-isms-procedure-for-internal-audits normain_audit_cycle_2025-2028. Fully meets the respective clause/control requirement.
9.3	Management Review		
9.3.1	General	C	08-isms-procedure-for-management-review version 1.0.0 dated 30/05/25 Management reviews of the ISMS are to be conducted at least annually to ensure its continuing suitability, adequacy, and effectiveness. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

9.3.2	Management Review Inputs	OBS	Reviewed 08-isms-procedure-for-management-review isms_management_review_2025-06-09 notes_management_review_of_the_isms_2025-06-09. It was observed that although the agenda items cover the requirements of the management review, the input topics were not fully covered during the first management review, as the internal audit was completed after the meeting. It would benefit the company to ensure that all topics on the agenda are covered accurately. Hence, this is considered as an Observation.
9.3.3	Management Review Results	C	08-isms-procedure-for-management-review isms_management_review_2025-06-09 notes_management_review_of_the_isms_2025-06-09. Fully meets the respective clause/control requirement.
10. Improvement			
10.1	Nonconformity and corrective action	C	09-isms-procedure-for-corrective-action-and-continual-improvement version 1.0.0 dated 30/05/25 nonconformity_and_corrective_action_log_-_normain. Fully meets the respective clause/control requirement.
10.2	Continual improvement	C	09-isms-procedure-for-corrective-action-and-continual-improvement version 1.0.0 dated 30/05/25 nonconformity_and_corrective_action_log_-_normain. Fully meets the respective clause/control requirement.

Annex A Controls

Control Objective and Control Description		Status of Finding	Audit Evidence (Finding and its Justification)
A.5 Organizational Controls			
A.5.1	Policies for Information Security Control: Information security policy and topic-specific policies shall be defined, approved by management, published, communicated to and acknowledged by relevant personnel and relevant interested parties, and reviewed at planned intervals and if significant changes occur.	C	access-control-policy-bsi asset-management-policy-bsi data-management-policy-bsi human-resource-security-policy-bsi information-security-policy-bsi operations-security-policy-bsi People-2025-07-27-135530 all policies accepted by employees. Fully meets the respective clause/control requirement.
A.5.2	Information Security Roles and Responsibilities Control: Information security roles and responsibilities shall be defined and allocated according to the organization needs.	C	03-isms-roles-responsibilities-and-authorities information-security-roles-and-responsibilities-bsi. Fully meets the respective clause/control requirement.
A.5.3	Segregation of Duties Control: Conflicting duties and conflicting areas of responsibility shall be segregated.	C	Normain Org Chart human-resource-security-policy-bsi Access configuration segregates duties. Fully meets the respective clause/control requirement.
A.5.4	Management Responsibilities Control: Management shall require all personnel to apply information security in accordance with the established information security policy, topic-specific policies and procedures of the organization.	C	information-security-policy-bsi information-security-roles-and-responsibilities-bsi. Fully meets the respective clause/control requirement.
A.5.5	Contact with Authorities Control: The organization shall establish and maintain contact with relevant authorities.	OBS	Reviewed incident-response-plan-bsi. It was observed that the contact list/ information of external authorities to be contacted in case of an information security incident or data breach is not available. Hence, this is considered as an Observation.
A.5.6	Contact with Special Interest Groups Control: The organization shall establish and maintain contact with special interest groups or other specialist security forums and professional associations.	C	information-security-roles-and-responsibilities-bsi detection_at_scale_newsletter SL - membership-certificate-2183857. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

A.5.7	Threat Intelligence Control: Information relating to information security threats shall be collected and analysed to produce threat intelligence.	C	cybersecurity_pulse fix_glib_critical_vulnerability_by_guslid_·_pull_request_#173_·_normainofficial_normain operations-security-policy-bsi. Fully meets the respective clause/control requirement.
A.5.8	Information Security in Project Management Control: Information security shall be integrated into project management.	C	risk-management-policy-bsi change_management_procedure risk_assessment_template. Fully meets the respective clause/control requirement.
A.5.9	Inventory of Information and Other Associated Assets Control: An inventory of information and other associated assets, including owners, shall be developed and maintained.	C	asset-management-policy-bsi monitored-computers-2025-07-27-140258 data_asset_inventory. Fully meets the respective clause/control requirement.
A.5.10	Acceptable use of Information and Other Associated Assets Control: Rules for the acceptable use and procedures for handling information and other associated assets shall be identified, documented and implemented.	C	information-security-policy-bsi data-management-policy-bsi asset-management-policy-bsi People-2025-07-27-135530 Acceptance of policies detailed. Fully meets the respective clause/control requirement.
A.5.11	Return of Assets Control: Personnel and other interested parties as appropriate shall return all the organization's assets in their possession upon change or termination of their employment, contract or agreement.	C	asset-management-policy-bsi Employment Termination Agreement Original employment agreement Offboarding checklist, LU LU'_factory_reset_computer. Fully meets the respective clause/control requirement.
A.5.12	Classification of Information Control: Information shall be classified according to the information security needs of the organization based on confidentiality, integrity, availability and relevant interested party requirements.	C	data-management-policy-bsi. Fully meets the respective clause/control requirement.
A.5.13	Labelling of Information Control: An appropriate set of procedures for information labelling shall be developed and implemented in accordance with the information classification scheme adopted by the organization.	C	data-management-policy-bsi. Fully meets the respective clause/control requirement.
A.5.14	Information Transfer Control: Information transfer rules, procedures, or agreements shall be in place for all types of transfer facilities within the	C	third-party-management-policy-bsi cryptography-policy-bsi Attachment 3 - Normain - Data Processing Agreement_Customer hosting Attachment 3 - Normain - Data Processing Agreement_Normain hosting. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

	organization and between the organization and other parties.		
A.5.15	Access Control Control: Rules to control physical and logical access to information and other associated assets shall be established and implemented based on business and information security requirements.	C	physical-security-policy-bsi int-20_PN_access_request_to_sustainability_roundtable int-2_new_employee_access_request_for_PN; Offboarding checklist, LU LU'_factory_reset_computer. Fully meets the respective clause/control requirement.
A.5.16	Identity Management Control: The full life cycle of identities shall be managed.	C	access-control-policy-bsi int-20_PN_access_request_to_sustainability_roundtable int-2_new_employee_access_request_for_PN; Offboarding checklist, LU LU'_factory_reset_computer. Fully meets the respective clause/control requirement.
A.5.17	Authentication Information Control: Allocation and management of authentication information shall be controlled by a management process, including advising personnel on appropriate handling of authentication information.	OBS	Reviewed access-control-policy-bsi information-security-policy-bsi Screenshot 2025-07-28 at 10.25.28. It was observed that MFA is recorded in Vanta for some but not all personnel against certain access systems, e.g., Notion, Slack. Hence, this is considered as an Observation.
A.5.18	Access Rights Control: Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed in accordance with the organization's topic-specific policy on and rules for access control.	C	access-control-policy-bsi int-22_annual_access_review_2025-06-19 screenshot_2025-06-04_at_15.48.01 vendor_master_sheet_access_review_2025-06-19_-_google_sheets. Fully meets the respective clause/control requirement.
A.5.19	Information Security in Supplier Relationships Control: Processes and procedures shall be defined and implemented to manage the information security risks associated with the use of supplier's products or services	C	third-party-management-policy-bsi vendors_data_export. Fully meets the respective clause/control requirement.
A.5.20	Addressing Information Security Within Supplier Agreements Control: Relevant information security requirements shall be established and agreed with each supplier based on the type of supplier relationship.	C	third-party-management-policy-bsi Microsoft Azure Service Agreement. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

A.5.21	Managing Information Security in the Information and Communication Technology (ICT) Supply Chain Control: Processes and procedures shall be defined and implemented to manage the information security risks associated with the ICT products and services supply chain.	C	third-party-management-policy-bsi. Fully meets the respective clause/control requirement.
A.5.22	Monitoring, Review and Change Management of Supplier Services Control: The organization shall regularly monitor, review, evaluate and manage change in supplier information security practices and service delivery.	C	third-party-management-policy-bsi vendor_master_sheet_-_vendor_master vendors_data_export. Fully meets the respective clause/control requirement.
A.5.23	Information Security for Use of Cloud Services Control: Processes for acquisition, use, management and exit from cloud services shall be established in accordance with the organization's information security requirements.	C	information-security-policy-bsi third-party-management-policy-bsi Microsoft Azure Service Agreement. Fully meets the respective clause/control requirement.
A.5.24	Information Security Incident Management Planning and Preparation Control: The organization shall plan and prepare for managing information security incidents by defining, establishing and communicating information security incident management processes, roles and responsibilities.	C	incident-response-plan-bsi. Fully meets the respective clause/control requirement.
A.5.25	Assessment and Decision on Information Security Events Control: The organization shall assess information security events and decide if they are to be categorized as information security incidents.	C	incident-response-plan-bsi nor1_-_incident_report_-_unrecognized_customer_data Actions detailed. Fully meets the respective clause/control requirement.
A.5.26	Response to Information Security Incidents Control: Information security incidents shall be responded to in accordance with the documented procedures.	C	incident-response-plan-bsi nor1_-_incident_report_-_unrecognized_customer_data Actions detailed. Fully meets the respective clause/control requirement.
A.5.27	Learning from Information Security Incidents Control: Knowledge gained from information security incidents shall be used to strengthen and improve the information security controls.	C	incident-response-plan-bsi nor1_-_incident_report_-_unrecognized_customer_data Actions detailed. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

A.5.28	Collection of Evidence Control: The organization shall establish and implement procedures for the identification, collection, acquisition and preservation of evidence related to information security events.	C	incident-response-plan-bsi. Fully meets the respective clause/control requirement.
A.5.29	Information Security During Disruption Control: The organization shall plan how to maintain information security at an appropriate level during disruption.	C	business-continuity-and-disaster-recovery-plan-bsi screenshot_2025-07-23_at_08.08.31 tabletop_disaster_recovery_exercise-links. Fully meets the respective clause/control requirement.
A.5.30	ICT Readiness for Business Continuity Control: ICT readiness shall be planned, implemented, maintained and tested based on business continuity objectives and ICT continuity requirements.	OFI	Reviewed business-continuity-and-disaster-recovery-plan-bsi incident-response-plan-bsi screenshot_2025-07-04_at_16.11.04 screenshot_2025-07-07_at_10.37.16 screenshot_2025-07-23_at_08.08.31. It was observed that the company may benefit by scheduling future plans for exercises and tests to support resilience in disaster recovery. Hence, this is considered as an Opportunity for Improvement.
A.5.31	Legal, Statutory, Regulatory and Contractual Requirements Control: Legal, statutory, regulatory and contractual requirements relevant to information security and the organization's approach to meet these requirements shall be identified, documented and kept up to date.	C	12-isms-relevant-laws-regulations-and-contractual-requirements Evaluation of compliance being measured. Fully meets the respective clause/control requirement.
A.5.32	Intellectual Property Rights Control: The organization shall implement appropriate procedures to protect intellectual property rights.	C	information-security-policy-bsi 12-isms-relevant-laws-regulations-and-contractual-requirements Sanitized & Signed employment agreement. Fully meets the respective clause/control requirement.
A.5.33	Protection of Records Control: Records shall be protected from loss, destruction, falsification, unauthorized access and unauthorized release.	C	05-isms-procedure-for-the-control-of-documented-information data-management-policy-bsi. Fully meets the respective clause/control requirement.
A.5.34	Privacy and Protection of Personal Identifiable Information (PII) Control: The organization shall identify and meet the requirements regarding the preservation of privacy and protection of PII according to applicable laws and regulations and contractual requirements.	C	12-isms-relevant-laws-regulations-and-contractual-requirements. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

A.5.35	Independent Review of Information Security Control: The organization's approach to managing information security and its implementation including people, processes and technologies shall be reviewed independently at planned intervals, or when significant changes occur.	C	07-isms-procedure-for-internal-audits normain_2025_06_12_18_14_02_v1 Normain Penetration Test Report 20250516 (1) closed_high_vulnerabilities. Fully meets the respective clause/control requirement.
A.5.36	Compliance with Policies, Rules and Standards for Information Security Control: Compliance with the organization's information security policy, topic-specific policies, rules and standards shall be regularly reviewed.	C	07-isms-procedure-for-internal-audits 08-isms-procedure-for-management-review closed_high_vulnerabilities risk-management-policy-bis. Fully meets the respective clause/control requirement.
A.5.37	Documented Operating Procedures Control: Operating procedures for information processing facilities shall be documented and made available to personnel who need them.	C	engineering_operation_procedures operations-security-policy-bis. Fully meets the respective clause/control requirement.
A.6 People Controls			
A.6.1	Screening Control: Background verification checks on all candidates to become personnel shall be carried out prior to joining the organization and on an ongoing basis taking into consideration applicable laws, regulations and ethics and be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.	C	human-resource-security-policy-bis Normain background check_FirstName_LastName_SANITIZED FOR VANTA Normain Talent Lifecycle Handbook Normain background check_TEMPLATE. Fully meets the respective clause/control requirement.
A.6.2	Terms and Conditions of Employment Control: The employment contractual agreements shall state the personnel's and the organization's responsibilities for information security.	C	human-resource-security-policy-bis information-security-policy-bis Sanitized & Signed employment agreement. Fully meets the respective clause/control requirement.
A.6.3	Information Security Awareness, Education and Training Control: Personnel of the organization and relevant interested parties shall receive appropriate information security awareness, education and training and regular updates of the organization's information security policy, topic-specific policies and procedures, as relevant for their job function.	C	human-resource-security-policy-bis People-2025-07-27-135530. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

A.6.4	Disciplinary Process Control: A disciplinary process shall be formalized and communicated to take actions against personnel and other relevant interested parties who have committed an information security policy violation.	C	human-resource-security-policy-bsi information-security-policy-bsi. Fully meets the respective clause/control requirement.
A.6.5	Responsibilities after Termination or Change of Employment Control: Information security responsibilities and duties that remain valid after termination or change of employment shall be defined, enforced and communicated to relevant personnel and other interested parties.	C	human-resource-security-policy-bsi Normain Employee Termination Checklist reminds of confidentiality agreement. Fully meets the respective clause/control requirement.
A.6.6	Confidentiality or Non-Disclosure Agreements Control: Confidentiality or non-disclosure agreements reflecting the organization's needs for the protection of information shall be identified, documented, regularly reviewed and signed by personnel and other relevant interested parties.	C	human-resource-security-policy-bsi external_non-disclosure_agreement_template internal_non-disclosure_agreement_template. Fully meets the respective clause/control requirement.
A.6.7	Remote Working Control: Security measures shall be implemented when personnel are working remotely to protect information accessed, processed or stored outside the organization's premises.	C	information-security-policy-bsi access-control-policy-bsi; MFA enabled. Fully meets the respective clause/control requirement.
A.6.8	Information Security Event Reporting Control: The organization shall provide a mechanism for personnel to report observed or suspected information security events through appropriate channels in a timely manner.	C	incident-response-plan-bsi information-security-policy-bsi. Fully meets the respective clause/control requirement.
A.7 Physical Controls			
A.7.1	Physical Security Perimeters Control: Security perimeters shall be defined and used to protect areas that contain information and other associated assets.	N/A	Statement of Applicability. The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.2	Physical Entry Control: Secure areas shall be protected by appropriate entry controls and access points.	N/A	Statement of Applicability. The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.3	Securing Offices, Rooms and Facilities	N/A	Statement of Applicability.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

	Control: Physical security for offices, rooms and facilities shall be designed and implemented.		The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.4	Physical Security Monitoring Control: Premises shall be continuously monitored for unauthorized physical access.	N/A	Statement of Applicability. The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.5	Protecting Against Physical and Environmental Threats Control: Protection against physical and environmental threats, such as natural disasters and other intentional or unintentional physical threats to infrastructure shall be designed and implemented.	N/A	Statement of Applicability. The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.6	Working in Secure Areas Control: Security measures for working in secure areas shall be designed and implemented.	N/A	Statement of Applicability. The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.7	Clear Desk and Clear Screen Control: Clear desk rules for papers and removable storage media and clear screen rules for information processing facilities shall be defined and appropriately enforced.	C	information-security-policy-bsi physical-security-policy-bsi sessionexpiration.png shows configuration for session expiry. monitored-computers-2025-07-25-133310 shows screenlock recorded on Vanta. Fully meets the respective clause/control requirement.
A.7.8	Equipment Siting and Protection Control: Equipment shall be sited securely and protected.	N/A	Statement of Applicability. The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.9	Security of Assets Off-Premises Control: Off-site assets shall be protected.	C	asset-management-policy-bsi information-security-policy-bsi monitored-computers-2025-07-25-133310 - hard drive encryption configured. Fully meets the respective clause/control requirement.
A.7.10	Storage Media Control: Storage media shall be managed through their life cycle of acquisition, use, transportation and disposal in accordance with the organization's classification scheme and handling requirements.	C	data-management-policy-bsi Information stored within cloud infrastructure - Azure. Fully meets the respective clause/control requirement.
A.7.11	Supporting Utilities Control: Information processing facilities shall be protected from power failures and other disruptions caused by failures in supporting utilities.	N/A	Statement of Applicability. The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.12	Cabling Security	N/A	Statement of Applicability.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

	Control: Cables carrying power, data or supporting information services shall be protected from interception, interference or damage.		The office premises are used solely as a working space and for occasional confidential meetings; no sensitive infrastructure is housed on-site, and no data is stored locally.
A.7.13	Equipment Maintenance Control: Equipment shall be maintained correctly to ensure availability, integrity and confidentiality of information.	C	third-party-management-policy-bsi physical-security-policy-bsi. Fully meets the respective clause/control requirement.
A.7.14	Secure Disposal or Re-Use of Equipment Control: terms of equipment containing storage media shall be verified to ensure that any sensitive data and licensed software has been removed or securely overwritten prior to disposal or re-use.	C	asset-management-policy-bsi data-management-policy-bsi. Fully meets the respective clause/control requirement.
A.8 Technological Controls			
A.8.1	User End Point Devices Control: Information stored on, processed by or accessible via user end point devices shall be protected.	C	operations-security-policy-bsi information-security-policy-bsi All devices are configured and recorded within Vanta. Xprotect AV in place, Harddrive encryption in place. Fully meets the respective clause/control requirement.
A.8.2	Privileged Access Rights Control: The allocation and use of privileged access rights shall be restricted and managed.	C	The company shall ensure that the allocation and use of privileged access rights are restricted and managed judiciously. access-control-policy-bsi Access level configuration reviewed within: azure board-easer cloudflare github1 Internal access reviews conducted periodically. int-22_annual_access_review_2025-06-19. Fully meets the respective clause/control requirement.
A.8.3	Information Access Restriction Control: Access to information and other associated assets shall be restricted in accordance with the established topic-specific policy on access control.	C	access-control-policy-bsi vendor_master_sheet_access_review_2025-06-19_-_google_sheets. Fully meets the respective clause/control requirement.
A.8.4	Access to Source Code Control: Read and write access to source code, development tools and software libraries shall be appropriately managed.	C	access-control-policy-bsi Github access restrictions and access controls observed within: github1.png github2.png. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

A.8.5	Secure Authentication Control: Secure authentication technologies and procedures shall be implemented based on information access restrictions and the topic-specific policy on access control.	OBS	Reviewed access-control-policy-bsi normain_network_diagram. It was observed that MFA is recorded in Vanta for some but not all personnel against certain access systems, e.g., Linear, Notion, Slack Hence, this is considered as an Observation.
A.8.6	Capacity Management Control: The use of resources shall be monitored and adjusted in line with current and expected capacity requirements.	C	Alert management in place to notify where threshold is exceeded for storage. Fatallogalert.png Monitoring metrics for utilisation metricsdashboard.png. Fully meets the respective clause/control requirement.
A.8.7	Protection Against Malware Control: Protection against malware shall be implemented and supported by appropriate user awareness.	C	operations-security-policy-bsi information-security-policy-bsi AV configured for devices monitored through Vanta, all devices configured. Fully meets the respective clause/control requirement.
A.8.8	Management of Technical Vulnerabilities Control: Information about technical vulnerabilities of information systems in use shall be obtained, the organization's exposure to such vulnerabilities shall be evaluated and appropriate measures shall be taken.	C	vulnerabilityscanreport.jpg security-headers-addressed.jpg pentest-remediation.jpg closed_high_vulnerabilities.jpg. Fully meets the respective clause/control requirement.
A.8.9	Configuration Management Control: Configurations, including security configurations, of hardware, software, services and networks shall be established, documented, implemented, monitored and reviewed.	C	Configuration settings determined within security-headers-addressed.jpg normain_network_diagram. Fully meets the respective clause/control requirement.
A.8.10	Information Deletion Control: Information stored in information systems, devices or in any other storage media shall be deleted when no longer required.	C	data-management-policy-bsi sets out approach for management in respect of deletion. customer-data-deletion-template Delete customer data runbook. Fully meets the respective clause/control requirement.
A.8.11	Data Masking Control: Data masking shall be used in accordance with the organization's topic-specific policy on access control and other related topic-specific policies, and business requirements, taking applicable legislation into consideration.	C	data-management-policy-bsi Encryption methods in place as detailed within: cryptography-policy-bsi. Fully meets the respective clause/control requirement.
A.8.12	Data Leakage Prevention Control: Data leakage prevention measures shall be applied to systems, networks and any	C	data-management-policy-bsi Encryption methods in place as detailed within: cryptography-policy-bsi.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

	other devices that process, store or transmit sensitive information.		Fully meets the respective clause/control requirement.
A.8.13	Information Backup Control: Backup copies of information, software and systems shall be maintained and regularly tested in accordance with the agreed topic-specific policy on backup.	C	operations-security-policy-bsi Recovery tests of back up data tested within screenshot_2025-07-23_at_08.08.31 Pre-documentation and After-report. Fully meets the respective clause/control requirement.
A.8.14	Redundancy of Information Processing Facilities Control: Information processing facilities shall be implemented with redundancy sufficient to meet availability requirements.	C	business-continuity-and-disaster-recovery-plan-bsi operations-security-policy-bsi normain_network_diagram redundantbackup.jpg database backup schedule. Fully meets the respective clause/control requirement.
A.8.15	Logging Control: Logs that record activities, exceptions, faults and other relevant events shall be produced, stored, protected and analysed.	C	operations-security-policy-bsi Dev logs detailed and show alert config: alertconfigurations fatallogalert. Fully meets the respective clause/control requirement.
A.8.16	Monitoring Activities Control: Networks, systems and applications shall be monitored for anomalous behaviour and appropriate actions taken to evaluate potential information security incidents	C	operations-security-policy-bsi Dev logs detailed and show alert config: alertconfigurations fatallogalert. Fully meets the respective clause/control requirement.
A.8.17	Clock Synchronization Control: The clocks of information processing systems used by the organization shall be synchronized to approved time sources.	C	operations-security-policy-bsi. Fully meets the respective clause/control requirement.
A.8.18	Use of Privileged Utility Programs Control: The use of utility programs that can be capable of overriding system and application controls shall be restricted and tightly controlled.	C	access-control-policy-bsi operations-security-policy-bsi MFA for all privileged access. Fully meets the respective clause/control requirement.
A.8.19	Installation of Software on Operational Systems Control: Procedures and measures shall be implemented to securely manage software installation on operational systems.	C	[normain]_third-party_management_policy.docx_(1) information-security-policy-bsi operations-security-policy-bsi analysis_of_installed_applications_2025-07-13. Fully meets the respective clause/control requirement.
A.8.20	Network Security Control: Networks and network devices shall be secured, managed and controlled to protect information in systems and applications.	C	normain_network_diagram operations-security-policy-bsi Network config subject to vulnerability scan vulnerabilityscanreport. Fully meets the respective clause/control requirement.

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

A.8.21	Security of Network Services Control: Security mechanisms, service levels and service requirements of network services shall be identified, implemented and monitored.	C	operations-security-policy-bsi third-party-management-policy-bsi. Fully meets the respective clause/control requirement.
A.8.22	Segregation of Networks Control: Groups of information services, users and information systems shall be segregated in the organization's networks.	C	normain_network_diagram operations-security-policy-bsi. Fully meets the respective clause/control requirement.
A.8.23	Web Filtering Control: Access to external websites shall be managed to reduce exposure to malicious content.	C	safe-browsing.jpg - displays configuration on webfiltering. Fully meets the respective clause/control requirement.
A.8.24	Use of Cryptography Control: Rules for the effective use of cryptography, including cryptographic key management, shall be defined and implemented.	C	cryptography-policy-bsi. Fully meets the respective clause/control requirement.
A.8.25	Secure Development Life Cycle Control: Rules for the secure development of software and systems shall be established and applied.	C	secure-development-policy-bsi. Fully meets the respective clause/control requirement.
A.8.26	Application Security Requirements Control: Information security requirements shall be identified, specified and approved when developing or acquiring applications.	C	secure-development-policy-bsi third-party-management-policy-bsi. Fully meets the respective clause/control requirement.
A.8.27	Secure System Architecture and Engineering Principles Control: Principles for engineering secure systems shall be established, documented, maintained and applied to any information system development activities.	C	secure-development-policy-bsi secure_system_engineering_principles secure_configuration_baselines_-_sheet1. Fully meets the respective clause/control requirement.
A.8.28	Secure Coding Control: Secure coding principles shall be applied to software development.	C	secure-development-policy-bsi secure_system_engineering_principles. Fully meets the respective clause/control requirement.
A.8.29	Security Testing in Development and Acceptance Control: Security testing processes shall be defined and implemented in the development life cycle.	C	secure-development-policy-bsi secure_system_engineering_principles quality_assurance_process Automated Security Testing Procedure Automated Security Testing Training - Facilitator Guide

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

			Automated Security Testing Training - Handout Automated Security Testing Training - Handout. Fully meets the respective clause/control requirement.
A.8.30	Outsourced Development Control: The organization shall direct, monitor and review the activities related to outsourced system development.	N/A	Statement of Applicability. All development is in-house.
A.8.31	Separation of Development, Test and Production Environments Control: Development, testing and production environments shall be separated and secured.	C	secure-development-policy-bsi normain_network_diagram Tasks detailed pr#229 qaandtesting. Fully meets the respective clause/control requirement.
A.8.32	Change Management Control: Changes to information processing facilities and information systems shall be subject to change management procedures.	C	operations-security-policy-bsi secure-development-policy-bsi quality_assurance_process change_management_procedure. Fully meets the respective clause/control requirement.
A.8.33	Test Information Control: Test information shall be appropriately selected, protected and managed.	C	secure-development-policy-bsi data-management-policy-bsi qa and testing. Fully meets the respective clause/control requirement.
A.8.34	Protection of Information Systems During Audit Testing Control: Audit tests and other assurance activities involving assessment of operational systems shall be planned and agreed between the tester and appropriate management.	C	operations-security-policy-bsi 07-isms-procedure-for-internal-audits. Fully meets the respective clause/control requirement.

AUDIT FINDINGS – INITIAL CERTIFICATION

Summary

Prescient Security strives to maintain clear and consistent communication with its clients throughout the audit process, ensuring that all relevant findings are shared promptly upon identification. This approach fosters effective communication among all participating team members.

During the closing meeting, the audit findings were thoroughly communicated to the client's representative. Additionally, the final conclusions of the audit and the recommendations made by the audit team were presented to the management.

Following the closing meeting, a Corrective Action Report (CAR) Finding Sheet was provided to the client. Detailed information regarding the findings, as well as their current status, is outlined below. The findings raised from this audit will be reviewed during your 2025 surveillance assessment.

AUDIT FINDING DEFINITIONS

The evaluation of the audit findings is based on the following definitions, in accordance with ISO/IEC 17021-1:

Major Non-Conformity (MaNC)

A non-conformity that affects the capability of the management system to achieve the intended results.

Minor Non-Conformity (MiNC)

A non-conformity that does not affect the capability of the management system to achieve the intended results.

Observations (OBS)

Any issues which are likely to become a NC, if not treated until the next audit are marked as observations. No response is required.

Opportunity for Improvement (OFI)

An opportunity for improvement is a finding that, should it go unaddressed, could result in more severe findings in subsequent reviews. An OFI can also be used to improve the management system as a whole or named processes. No response is required.

STAGE 2 CERTIFICATION AUDIT – FINDINGS & OUTCOMES

Nonconformities

NC Type	Clause / Control No	Clause / Control Requirement	Details of Nonconformities	Status of Finding & Evidence Reviewed
N/A	N/A	N/A	N/A	N/A

Observations

Clause/Control No	Details
ISO/IEC 27001:2022 Clause 9.3.2	Evidence Reviewed 08-isms-procedure-for-management-review isms_management_review_2025-06-09 notes_management_review_of_the_isms_2025-06-09. It was observed that although the agenda items cover the requirements of the management review, the input topics were not fully covered during the first management review, as the internal audit was completed after the meeting. It would benefit the company to ensure that all topics on the agenda are covered accurately. Hence, this is considered as an Observation.
ISO/IEC 27001:2022 Control A.5.5	Evidence Reviewed incident-response-plan-bsi. It was observed that the contact list/ information of external authorities to be contacted in case of an information security incident or data breach is not available. Hence, this is considered as an Observation.
ISO/IEC 27001:2022 Control A.5.17	Evidence Reviewed access-control-policy-bsi information-security-policy-bsi Screenshot 2025-07-28 at 10.25.28. It was observed that MFA is recorded in Vanta for some but not all personnel against certain access systems, e.g., Notion, Slack. Hence, this is considered as an Observation.
ISO/IEC 27001:2022 Control A.8.5	Evidence Reviewed access-control-policy-bsi normain_network_diagram. It was observed that MFA is recorded in Vanta for some but not all personnel against certain access systems, e.g., Linear, Notion, Slack Hence, this is considered as an Observation.

Opportunities for Improvement

Clause/Control No	Details
-------------------	---------

The contents of this audit report are confidential. Findings raised within this report are the result of limited sampling. The audit is based on a sampling process of the available information and the auditors nor Prescient Security can guarantee that all, if any, non-conformities have been discovered.

ISO/IEC 27001:2022 Control A.5.30	Evidence Reviewed business-continuity-and-disaster-recovery-plan-bsi incident-response-plan-bsi screenshot_2025-07-04_at_16.11.04 screenshot_2025-07-07_at_10.37.16 screenshot_2025-07-23_at_08.08.31. It was observed that the company may benefit by scheduling future plans for exercises and tests to support resilience in disaster recovery. Hence, this is considered as an Opportunity for Improvement.
--------------------------------------	---

SECTION 4:

AUDIT CONCLUSIONS & AUDIT TEAM RECOMMENDATION

AUDIT CONCLUSIONS AND AUDIT RECOMMENDATIONS

Audit Conclusion

The Information Security Management System has proven conformity with the requirements of the ISO/IEC 27001:2022 standard. It has also provided the adequate structure to support implementation and maintenance of the information security management system.

There has been no serious deviation from the audit plan. No significant issues were found that could impact the audit program. Additionally, there have been no significant changes or any unresolved issues affecting the management system since the last audit took place as this is the initial certification audit for Normain AB, who has not been previously certified for ISO/IEC 27001:2022.

The audit team is pleased to confirm that the ISMS is designed to achieve the organization's policy objectives. The ISMS also meets statutory, regulatory and contractual requirements.

The audit team delved into the internal audit and management review processes to ensure that the organization is committed. The audit team can confirm that the internal audit and management review processes are in place and adequate.

In conclusion, the audit, although conducted remotely, was successful in meeting the stated objectives for 2024 initial certification audit.

Audit Recommendation

At the recommendation of the appointed audit team, we have determined that, based on the currently identified audit findings, we can recommend certification issuance to the Prescient Security certification body management team.

Additionally, the audit team found that the certificate scope was appropriate and that all intended audit objectives were sufficiently fulfilled to the extent that there were no unresolved issues that affected the audit team's ability to conclude the assessment.

The audit team recommends Normain AB for ISO/IEC 27001:2022 certification.

Signed,

Barry Jones

Barry Jones
Lead Auditor
Prescient Security LLC